

**SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)**  
**C04- ASSESSMENT TOOL - 1**

---

|                         |                    |                      |                   |
|-------------------------|--------------------|----------------------|-------------------|
| <b>Course Code:</b>     | ITA1407            | <b>Course Title:</b> | Ethical Hacking   |
| <b>CO Assessed:</b>     | CO4                | <b>Assessment :</b>  | Assessment Tool 1 |
| <b>Weightage:</b>       | 40%                |                      |                   |
|                         |                    |                      |                   |
| <b>Student Name:</b>    | Mohammed Safwaan M | <b>Reg. No.:</b>     | 192421385         |
| <b>Section / Batch:</b> | B tech IT          | <b>Date:</b>         | 20-08-2026        |

**Code of Conduct**

*I, Mohammed Safwaan M, certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the Student: Mohammed Safwaan M

# VULNERABILITY ASSESSMENT REPORT

## 1. Introduction

Wireless networks are widely used in companies because they make it easier for employees and devices to connect to the organization's systems. At the same time, an insecure wireless network can become an entry point for an attacker.

The TJX Companies data breach is a well-known example of this problem. TJX was a large retail company that handled a large amount of customer and payment information. During the incident, attackers gained unauthorized access to the company's network and sensitive payment-card information was compromised.

The incident was not caused by only one security problem. Weak wireless protection, insufficient access control, poor network separation, inadequate monitoring and weaknesses in protecting payment information all increased the overall risk.

This report examines these vulnerabilities and explains how stronger wireless security and network-security controls could have reduced the risk.

---

## 2. Background of the TJX Incident

TJX Companies disclosed the intrusion in January 2007. Investigations into the incident found that attackers had gained access through wireless networks associated with TJX stores.

One important weakness was the use of WEP (Wired Equivalent Privacy). TJX had planned to move from WEP to WPA, but the transition was still taking place when the incident occurred.

The investigation found that the wireless security was not strong enough and that sensitive systems were not sufficiently protected from the wireless environment. The incident eventually resulted in the exposure of a very large amount of payment-card information.

The U.S. Federal Trade Commission later found that TJX had failed to use reasonable security measures to protect sensitive information and required the company to establish a comprehensive information-security program.

---

## 3. Objective of the Vulnerability Assessment

The main objective of this assessment is to identify the security weaknesses that contributed to the TJX incident and understand how those weaknesses could affect an organization.

The assessment focuses on:

- Wireless encryption
- Wireless authentication
- Network segmentation
- Firewall and access controls
- Wireless monitoring
- Rogue access-point detection
- Payment-data protection
- PCI DSS security controls

The assessment also provides recommendations for improving the security of a similar retail wireless environment.

---

## 4. Assessment Methodology

This assessment was performed as a case-study based vulnerability assessment.

Publicly available information about the TJX incident was studied and the reported weaknesses

were compared with modern wireless and network-security practices.

The basic methodology used was:

**Identify vulnerability → Understand possible exploitation → Assess impact → Assign risk → Recommend mitigation**

No real TJX systems were tested or attacked. The purpose of the assessment is to understand the security weaknesses and recommend defensive measures.

---

## 5. Simplified Attack Scenario

The incident can be understood using the following basic flow:

**Attacker near store**



**Identifies wireless network**



**Weak WEP security is targeted**



**Unauthorized wireless access**



**Access to internal network**



**Poor segmentation allows further access**



**Sensitive transaction/payment systems become reachable**



**Payment information may be exposed**

The important point is that compromising the wireless network should not automatically give an attacker access to sensitive payment systems. Proper segmentation and access controls should have stopped or limited this movement.

---

## 6. Vulnerabilities Identified

### 6.1 Weak Wireless Encryption – WEP

One of the major vulnerabilities in the TJX case was the use of WEP.

WEP was an older wireless security protocol and had serious weaknesses in its cryptographic design. It was not suitable for protecting a large business network that handled sensitive payment information.

An attacker who was within wireless range could potentially collect wireless traffic and use weaknesses in WEP to obtain unauthorized access.

For this reason, WEP should not be used in an enterprise environment.

**Risk Level: Critical**

**Impact:** An attacker may gain unauthorized access to the wireless network and use it as a starting point for further attacks.

---

### 6.2 Weak Wireless Authentication and Access Control

Wireless encryption and authentication are different security controls. Even if the network uses encryption, the organization must still control who and what is allowed to connect.

A business environment should not depend on one shared wireless password for everyone. If the password is discovered, an unauthorized person may be able to connect.

A better solution is enterprise authentication using IEEE 802.1X and EAP. This allows individual

users or devices to be authenticated through a central authentication server.

**Risk Level: Critical**

**Impact:** Unauthorized devices or users may gain access to the internal network.

---

### 6.3 Poor Network Segmentation

Network segmentation was another important issue.

A wireless network used by employees or store devices should not have unrestricted access to payment-processing systems.

For example, a guest Wi-Fi network should be completely separated from the payment network.

Employee devices should also have only the access required for their work.

If an attacker compromises a wireless network, proper segmentation can prevent the attacker from moving directly toward sensitive systems.

**Risk Level: Critical**

**Impact:** A wireless compromise can become a larger internal network compromise.

---

### 6.4 Weak Firewall and Access Controls

Firewalls should control communication between different parts of the network.

For example, a wireless client should not be allowed to communicate directly with a payment database unless there is a specific business requirement.

The recommended approach is to allow only required connections and block unnecessary traffic.

Firewall rules should be regularly reviewed because unnecessary rules can create additional paths for attackers.

**Risk Level: High**

**Impact:** Attackers who gain wireless access may be able to communicate with systems that should normally be inaccessible.

---

### 6.5 Insufficient Monitoring

Another weakness was the lack of effective monitoring and detection.

Security teams should be able to identify unusual wireless connections, unknown devices, repeated authentication failures, suspicious network traffic and unexpected access to sensitive systems.

If security events are not monitored properly, an attacker can remain inside a network for a longer period.

Wireless monitoring should also be connected with other security logs such as firewall, authentication and server logs.

**Risk Level: High**

**Impact:** A security breach may remain undetected for a long time.

---

### 6.6 Weak Payment-Data Protection

Payment-card information is extremely valuable to attackers.

Once an attacker reaches systems that process or store payment information, the consequences can be much more serious than a normal network compromise.

Sensitive payment information should be minimized, properly protected and encrypted when transmitted.

Organizations should also restrict access to payment information and monitor systems that handle cardholder data.

**Risk Level: Critical**

**Impact:** Exposure of payment information can result in financial losses, fraud, legal consequences,

compliance issues and damage to the company's reputation.

---

## 7. Risk Assessment Summary

| Vulnerability           | Risk Level | Main Reason                                    |
|-------------------------|------------|------------------------------------------------|
| WEP encryption          | Critical   | Weak wireless protection                       |
| Wireless access control | Critical   | Unauthorized devices may connect               |
| Network segmentation    | Critical   | Wireless access may lead to sensitive systems  |
| Firewall controls       | High       | Unnecessary network paths may exist            |
| Monitoring              | High       | Attacks may remain undetected                  |
| Payment-data protection | Critical   | Sensitive financial information may be exposed |

---

## 8. Recommended Security Controls

The first step should be to completely remove WEP.

Modern enterprise wireless networks should use WPA2-Enterprise or WPA3-Enterprise with strong encryption.

For new wireless deployments, WPA3-Enterprise should be considered where supported. WPA2-Enterprise is also widely used in enterprise environments.

Enterprise wireless security is better than a simple shared password because users and devices can be authenticated individually.

---

### 8.2 IEEE 802.1X Authentication

IEEE 802.1X should be used to control access to the enterprise wireless network.

It can work together with EAP and a central authentication server.

This provides several advantages:

- Individual authentication
- Centralized access management
- Better accountability
- Easier removal of a user's access
- Support for certificate-based authentication
- Reduced dependence on shared passwords

For example, if an employee leaves the organization, their individual access can be disabled without changing the wireless password for every other employee.

---

### 8.3 Network Segmentation

The network should be divided into separate security zones.

A possible structure would be:

#### Guest Wi-Fi



No access to internal systems

#### Employee Wi-Fi



Limited access to business applications

#### Retail Devices



Access only to required services

## **Payment Network**



Highly restricted access

## **Cardholder Data Environment**



Strong firewall and access controls

This type of design limits the damage if one part of the network is compromised.

---

### **8.4 Rogue Access-Point Detection**

A rogue access point is an unauthorized wireless device connected to or pretending to be part of an organization's wireless network.

The organization should use Wireless Intrusion Detection or Prevention Systems (WIDS/WIPS) to monitor the wireless environment.

Recommended controls include:

- Maintain an inventory of authorized access points.
- Continuously monitor the wireless environment.
- Detect unknown access points.
- Investigate suspicious SSIDs.
- Monitor unauthorized wireless clients.
- Perform physical checks of wireless equipment.
- Create a procedure for removing unauthorized devices.

This would improve the organization's ability to detect wireless attacks.

---

### **8.5 Wireless Monitoring**

Wireless monitoring should not be performed separately from the rest of the security environment.

The organization should collect and review:

- Wireless authentication events
- Failed login attempts
- New devices
- Rogue access points
- Firewall events
- Unusual network traffic
- Access to payment systems
- Administrative activity

These logs can be sent to a centralized monitoring system such as a SIEM.

The main goal is to detect suspicious behavior as early as possible.

---

## **9. PCI DSS Considerations**

PCI DSS is especially important for an organization such as TJX because it handles payment-card information.

Important security areas include:

### **Network Security**

Firewalls and network-security controls should separate the cardholder data environment from less trusted networks.

### **Access Control**

Users should only receive the access required for their job.

### **Authentication**

Individual accounts and strong authentication should be used, especially for administrators.

### **Data Protection**

Payment information should be minimized and properly protected.

### **Encryption**

Sensitive payment information should be protected using strong cryptography when transmitted across networks.

### **Logging and Monitoring**

Security events should be logged and reviewed regularly.

### **Wireless Security**

Wireless networks should use strong security and should be checked for unauthorized wireless devices.

### **Security Testing**

Regular vulnerability assessments and authorized penetration tests should be performed.

---

## **10. How the Recommended Controls Could Have Reduced the Risk**

There is no single security control that can guarantee that a breach will never happen. The best approach is to use multiple security layers.

Replacing WEP with stronger wireless security would have made unauthorized wireless access more difficult.

Using 802.1X would have provided better control over which users and devices could connect.

Network segmentation would have limited what an attacker could access after compromising the wireless network.

Firewall rules would have blocked unnecessary communication between wireless users and sensitive systems.

Rogue-access-point detection would have improved visibility into unauthorized wireless devices.

Better logging and monitoring could have helped security staff identify suspicious activity earlier.

Strong protection of payment information would have reduced the impact even if an attacker managed to compromise part of the network.

---

## **11. Ethical-Hacking Perspective**

From an ethical-hacking point of view, the important lesson from the TJX incident is that finding one vulnerability is not enough.

For example, if an assessor finds that a wireless network is using weak encryption, the next question should be:

### **"What can an attacker reach after gaining wireless access?"**

If the wireless network is properly segmented, the impact may be limited.

If the wireless network has unrestricted access to sensitive systems, the risk becomes much higher.

Therefore, a vulnerability assessment should consider both the initial weakness and the possible consequences after exploitation.

Any practical testing should only be performed on systems for which written authorization has been provided. A safe college demonstration can use a controlled lab network rather than a real company's network.

---

## **12. Risk Treatment Plan**

### **Priority Recommended Action**

1 Remove WEP

### **Expected Result**

Stronger wireless security



| Priority | Recommended Action                     | Expected Result                               |
|----------|----------------------------------------|-----------------------------------------------|
| 2        | Implement WPA2/WPA3 Enterprise         | Better wireless authentication and encryption |
| 3        | Implement 802.1X                       | Individual user/device authentication         |
| 4        | Separate wireless and payment networks | Reduced lateral movement                      |
| 5        | Deploy WIDS/WIPS                       | Better rogue-device detection                 |
| 6        | Improve centralized monitoring         | Faster detection                              |
| 7        | Strengthen administrator accounts      | Reduced privileged-access risk                |
| 8        | Protect payment information            | Reduced impact of a breach                    |
| 9        | Perform regular security testing       | Earlier identification of weaknesses          |

---

### 13. Overall Assessment

The TJX incident shows that wireless security cannot be considered separately from the rest of the organization's network security.

The use of weak wireless protection created an important security weakness. However, the overall impact became much greater because other controls such as segmentation, monitoring, access control and payment-data protection were also not strong enough.

The main lesson is that organizations should use multiple layers of security. Even if an attacker manages to compromise one part of the network, other controls should prevent the attacker from reaching the most sensitive systems.

---

### 14. Conclusion

The TJX Companies wireless network breach is an important example of how an insecure wireless environment can contribute to a large-scale data breach.

The main weaknesses identified in this assessment are weak wireless encryption, insufficient authentication, poor network segmentation, inadequate firewall controls, insufficient monitoring and weaknesses in payment-data protection.

The use of WPA2-Enterprise or WPA3-Enterprise, IEEE 802.1X authentication, proper network segmentation, strong firewall rules, rogue-access-point detection, centralized monitoring and PCI DSS security controls would significantly reduce the risk of a similar incident.

The most important security lesson from this case is that protecting the wireless network alone is not enough. The entire path from the wireless connection to the sensitive payment environment must be protected using multiple security controls.

---

### 15. References

1. U.S. Federal Trade Commission. "TJX Companies, Inc. Data Security Settlement." Federal Trade Commission.
  2. Office of the Privacy Commissioner of Canada. "Report of an Investigation into the Security, Collection and Retention of Personal Information - TJX Companies Inc."
  3. PCI Security Standards Council. "PCI DSS: Payment Card Industry Data Security Standard."
  4. PCI Security Standards Council. "PCI DSS Wireless Guidelines."
  5. IEEE. "IEEE 802.1X – Port-Based Network Access Control."
  6. Wi-Fi Alliance. "Wi-Fi CERTIFIED WPA3 Security."
-